BrandStore — API Contract Review and Application Plan (Phase 2, Task 1)

Author: Ahmed · Date: 2026-11-12 · Branch: `feature/api-contract-and-app-plan` · Same content as PDF: `REPORT.pdf`

Run: `npm install` then `npm run start` (http://127.0.0.1:8080). API: `npm run mock` (port 4010, login `demo@brandstore.test` / `Passw0rd!`).

1. Endpoint Table

Spec: `api/openapi.json`. Observed: `npm run contract` sent 45 requests to the mock server and found 0 differences from the spec (full log: `docs/api/ENDPOINTS.md`).

Method	Path	Auth	Status codes in spec	Status codes observed	Success JSON
GET	`/products?category&q&minPrice&maxPrice&inStock&sort&page&limit`	none	200, 400, 429	200, 400, 429	`{ data: Product[], meta: { page, limit, total, totalPages } }`
GET	`/products/{id}`	none	200, 400, 404, 429	200, 400, 404, 429	`{ data: Product + { description, specs } }`
POST	`/auth/login`	none	200, 400, 401, 429	200, 400, 401, 429	`{ data: { token, tokenType, expiresIn, user } }`
GET	`/account/orders?status&page&limit`	Bearer	200, 400, 401, 429	200, 400, 401, 429	`{ data: Order[], meta }`
PATCH	`/account/orders/{id}/cancel`	Bearer	200, 400, 401, 404, 429	200, 400, 401, 404, 429	`{ data: Order }`
GET	`/account/addresses`	Bearer	200, 401, 429	200, 401, 429	`{ data: Address[] }`
PUT	`/account/addresses/{id}`	Bearer	200, 201, 400, 401, 429	200, 201, 400, 401, 429	`{ data: Address }` (201 = created)
DELETE	`/account/addresses/{id}`	Bearer	200, 401, 404, 429	200, 401, 404, 429	`{ data: { id, deleted: true } }`

Errors: `{ error: { code, message, details? } }`. 400 = invalid input (`VALIDATION_ERROR`, `INVALID_JSON`, `ORDER_NOT_CANCELLABLE`); 401 = no or bad token (`UNAUTHENTICATED`, `INVALID_TOKEN`) or wrong password (`INVALID_CREDENTIALS`); 404 = `NOT_FOUND`; 429 = more than 60 requests per minute (`RATE_LIMITED`) or a 6th failed login within a minute (`TOO_MANY_LOGIN_ATTEMPTS`), with `Retry-After`. Prices are integer cents.

2. Storage Strategy

Decided by what must survive a **refresh**, **closing the tab**, and **logout**.

Data	Storage	Survives refresh	Survives tab close	Survives logout	Why
Cart	localStorage `brandstore:cart:v1`	Yes	Yes	Yes	Shoppers expect their cart tomorrow; it has no personal data; prices are re-checked with the API before checkout
Save for later	localStorage `brandstore:saved:v1`	Yes	Yes	Yes	A wishlist is only useful if it lasts
Sign-in (token, expiry, user)	sessionStorage `brandstore:session:v1`	Yes	**No**	**No**	Refresh must not sign you out, but a token must not outlive the tab on a shared computer; removed on logout and on any 401
Session flags (return-to page, notices)	sessionStorage `brandstore:flags:v1`	Yes	**No**	**No**	Only meaningful during this visit
Filters, sort, page	URL query string	Yes	via history/bookmark	Yes	Shareable links, Back button works
Orders, addresses	memory only	refetched	**No**	**No**	Personal data; the server is the source of truth

Trade-offs (XSS, cookies, versioned keys, private mode): `docs/STORAGE.md`.

3. QA Matrix

Check	Chrome desktop 1280	Chrome phone 375	Firefox	Safari / WebKit
Products and testimonials render; no global variables	Pass	Pass	Not run	Not run
Category filter and category links	Pass	Pass	Not run	Not run
Deals previous / next	Pass	Pass	Not run	Not run
Newsletter error and success messages	Pass	Pass	Not run	Not run
Skip link and keyboard focus	Pass	Pass	Not run	Not run
Phone menu (open, Escape, focus back)	n/a	Pass	Not run	Not run
Comparison table highlight	Pass	Pass	Not run	Not run
404 page	Pass	Pass	Not run	Not run

Source: `npm run e2e`, 17 of 17 runs passed. Firefox and Safari were not installed in the build environment.

Other check	Command	Result
Lint	`npm run lint`	0 problems
Formatting	`npm run format:check`	all files formatted
ES-module rules (no classic or inline scripts, no globals, functions ≤ 40 lines)	`node qa/js-rules.js`	0 failures
Build	`npm run build`	OK: every page reference and import resolves
API contract	`npm run contract`	45 requests, 0 problems
Unit tests	`npm test`	37 pass (run through a Vitest-compatible shim; see deviation 5)
Phase 1 behaviour, layout, keyboard, accessibility audit	`npm run qa`, `qa/*.js`	all pass (41/41 behaviour, 163/163 audit)

4. Deviations List

#	Deviation	Reason
1	The OpenAPI spec and mock server were written by me	None was provided with the task; `SPEC=<file> API_URL=<url> npm run contract` re-checks official ones
2	Endpoints exercised by a script, not by hand in a REST client	Repeatable; the same requests are in `docs/api/brandstore.postman_collection.json` for Postman
3	Address PUT/DELETE use `/account/addresses/{id}`	A collection-level PUT/DELETE would replace or delete every address
4	Non-cancellable order returns 400 (not 409); DELETE returns 200 with a body (not 204)	Stay within the status codes listed in the task
5	No `package-lock.json`; unit tests run through a shim, not real Vitest	No package registry access in the build environment; run `npm install` and `npm test`
6	The site must be opened over http, not by double-clicking the file	Browsers do not load ES modules from `file://`
7	`build` copies and checks files instead of bundling	Vite is allowed as a dev server only
8	Cart, sign-in, orders and addresses are not on the site yet	This task is planning; they are designed (sections 2, 5) and built in the next task

5. Module Layout (ES modules)

Every page loads exactly one external ES module and no other script: `index.html` → `src/pages/home.js`, `comparison.html` → `src/pages/comparison.js`, `404.html` → `src/pages/not-found.js`. No inline scripts, no `window` globals, every function named, commented and at most 40 lines.

Folder	Owns	May import
`src/pages/`	One entry per page; lists the features it starts	`main.js`, `components/`

Folder	Owns	May import
`src/main.js`	`start()`: runs features, one failure cannot stop the others	—
`src/components/`	One piece of UI each (nav, filter, deals, newsletter, table; planned: cart, login, orders, addresses)	`api/`, `state/`, `utils/`
`src/state/`	What the app remembers (content now; cart, saved, session, filters planned)	`utils/`
`src/api/`	REST calls: one `fetch` wrapper plus one file per resource (planned)	`utils/`
`src/utils/`	Pure helpers: DOM, validation, money, cart math, query strings, storage	nothing

ESLint enforces these import rules, allows `fetch` only in `src/api/http.js` and Web Storage only in `src/utils/storage.js`. Details: `docs/ARCHITECTURE.md`.

6. What the Site Does Today vs Planned

Feature	Today
Product cards, testimonials, category filter, deals strip, newsletter form, mobile menu, skip link, comparison table, 404 page	**On the site** (all covered by the QA matrix)
Catalogue from the API (search, price range, sort, pages), cart, save for later, sign-in, order history and cancel, address book	**Planned**: API contract, storage and modules are designed here; code stubs exist in `src/api`, `src/state`, `src/utils` but no page uses them yet

7. How Shoppers Can Trust Prices, Stock and Order History

This is the design for the cart and account features built in the next task.

- **Prices:** always from the API, in integer cents; the cart price is re-checked before checkout.
- **Stock:** from the API's `stock`; quantity limited to what is in stock; out-of-stock items cannot be added.
- **Order history:** always loaded from the server, never stored on the device; "Cancel" only when the API says `cancellable: true`.
- **Browse and filter:** filters live in the URL, so links and Back work; bad values are corrected before calling the API.

8. npm Scripts, Test Plan and Branch

Script	Does
`dev`	Vite dev server
`build`	Copy site to `dist/` and verify every reference and import
`lint` / `format`	ESLint / Prettier (`format:check` to only check)
`test`	Vitest unit tests
`e2e`	Browser journeys (Playwright)
`start`, `preview`, `mock`, `contract`, `qa`, `branch:check`, `check`	serve, serve `dist/`, mock API, contract check, Phase 1 QA, branch rule, everything

Test plan (`docs/TEST_PLAN.md`): the highest-risk modules are **cart math** (unit + integration + e2e), **auth** (unit + integration with MSW + e2e) and **query-string building** (unit + integration + e2e).

Branch convention (`CONTRIBUTING.md`): `<type>/<short-description>`, type = feature, fix, docs, chore, test or refactor, lowercase kebab-case, at most 50 characters. This branch: `feature/api-contract-and-app-plan`.

9. Changes Since the Last Review

- The required sections (Endpoint Table, Storage Strategy, QA Matrix, Deviations List) are now the first four sections of this short report.
- The last classic script (`src/boot.js`) is gone: every page now loads only one ES module. The mobile-menu CSS uses `@media (scripting: enabled)` instead.
- All checks re-run after the change (section 3).

More detail: `docs/ARCHITECTURE.md`, `docs/STORAGE.md`, `docs/TEST_PLAN.md`, `docs/api/ENDPOINTS.md`, `CHANGELOG.md`. Phase 1 documents: `docs/phase1/README.md`, `LAUNCH_REPORT.md`.